

Manual 04 - Implementação do Perfil de IA Generativa NIST AI 600-1

CANDIDATO CONTROLADO PARA QA DE PUBLICACAO

Revisão da fonte controlada: 2b1e27f06c1f35ff2b95b8b528a30aae4682bd5d | Idioma: pt-BR | Perfil de IA Generativa NIST AI 600-1 com o framework principal AI RMF 1.0; controle de versão e monitoramento de fontes.

Limite de asseguração: Este manual voluntário de implementação não certifica um sistema de IA generativa, não estabelece conformidade legal, não demonstra por si só uma IA confiável nem fornece uma opinião de auditoria; nem toda ação sugerida se aplica a cada ator, sistema, caso de uso ou contexto do ciclo de vida.

Caminhos de implementação e modelo operacional

Manual 04 - caminhos de implementacao

Proposito e limite de controle

Esta incorporacao converte o NIST AI 600-1 em trabalho de implementacao escalavel sem transformar acoes sugeridas voluntarias em requisitos universais. Cada organizacao deve determinar a aplicabilidade com base em seu inventario de IA generativa (GAI), nas tarefas dos atores de IA, na etapa do ciclo de vida, no contexto de uso, nas partes afetadas, na tolerancia a risco, nas obrigacoes aplicaveis e nos recursos.

Os tres caminhos alteram a profundidade, a independencia, a frequencia e a evidencia esperadas. Eles nao alteram a necessidade de compreender riscos materiais de GAI, atribuir decisoes responsaveis, interromper ou reverter uso inaceitavel, responder a incidentes e manter evidencia defensavel.

1. Selecionar um caminho proporcional

Caminho essencial

Use quando a presenca de GAI for restrita, a organizacao for pequena, os casos de uso tiverem baixa complexidade e nao tiver sido identificado impacto material de seguranc, direitos, servicos criticos, dados altamente sensiveis, alta capacidade ou informacao publica em grande escala.

Conjunto operacional minimo:

- executivo ou proprietario nomeado para o risco de GAI;
- inventario de modelos, servicos, integracoes, casos de uso, usuarios e dados aprovados;
- regras de uso aceitavel e uso proibido;
- triagem das doze familias de risco de GAI;
- verificacoes basicas de privacidade, seguranc, propriedade intelectual, conteudo e fornecedores;
- revisao humana documentada para resultados consequenciais;
- criterios definidos de liberacao, parada, rollback e escalonamento de incidentes;
- monitoramento periodico e reavaliacao apos mudanca material; e
- um registro de evidencias vinculando decisoes, testes, achados, remediacao e risco residual.

Caminho estruturado

Use quando houver varios sistemas de GAI ou unidades de negocio, dados sensiveis ou processos regulados, saidas para clientes forem materiais, dependencias de terceiros forem significativas ou a organizacao precisar de asseguracao repetivel.

Adicione ao caminho Essencial:

- forum formal de governanca de GAI e mapa de atores/responsabilidades;
- registro de aplicabilidade e adaptacao acao por acao;
- avaliacoes de risco de modelo, sistema, caso de uso e ecossistema;
- plano de TEVV pre-implantacao e red teaming baseado em risco;
- controles de proveniencia de conteudo e integridade da informacao;

- feedback representativo de usuarios e partes afetadas;
- due diligence de fornecedores, clausulas contratuais, monitoramento e planos de saida documentados;
- revisao independente de decisoes de liberacao de maior risco;
- metricas, limites, alertas, divulgacao de incidentes e fluxo de acao corretiva definidos; e
- revisao programada da efetividade de controles e relatorios gerenciais.

Caminho aprimorado

Use para GAI de alta capacidade ou amplamente implantada, exposicao material de seguranca nacional ou CBRN, contextos criticos de seguranca ou servicos essenciais, decisoes de alto impacto, populacoes vulneraveis, efeitos de integridade da informacao em grande escala, propriedade intelectual de alto valor ou cadeias de valor complexas.

Adicione ao caminho Estruturado:

- avaliacao tecnica e de dominio independente;
- testes adversariais contra modelos de ameaca e casos de uso indevido realistas;
- ambientes de avaliacao controlados e dados de teste protegidos;
- analise quantitativa e qualitativa de incerteza;
- monitoramento continuo de drift, mudancas de capacidade, uso indevido emergente e falhas correlacionadas;
- separacao entre desenvolvimento, validacao, liberacao e aprovacao do risco residual;
- procedimentos ensaiados de contencao, desligamento de modelo/servico, fallback e recuperacao;
- monitoramento aprimorado de uso downstream e do ecossistema;
- planos formais de comunicacao com partes afetadas, reguladores, clientes e fornecedores; e
- supervisao do conselho ou equivalente para riscos acima da tolerancia delegada.

Gráfico de memória do Manual 04 1

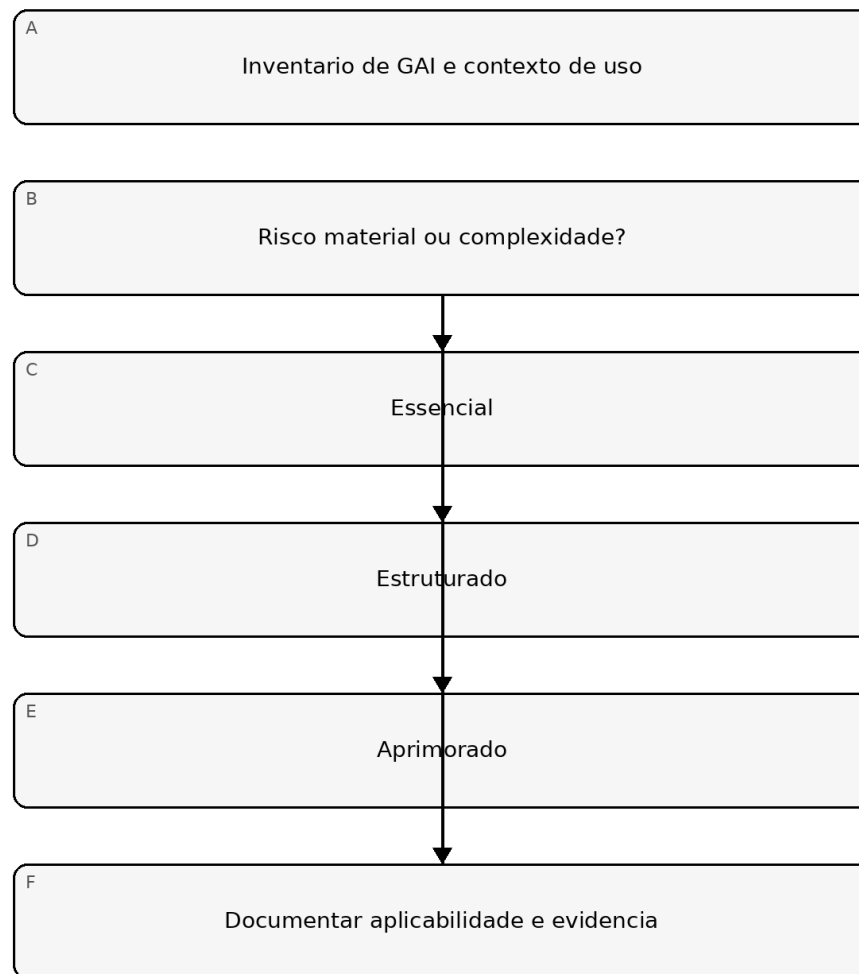


Figura 1. Gráfico de memória de implementação

Explicação acessível: Comece pelo inventário de GAI e pelo contexto real. Usos baixos e delimitados podem utilizar controles Essenciais; usos múltiplos ou sensíveis precisam de controles Estruturados; usos de alta capacidade ou alto impacto precisam de controles Aprimorados. Todo caminho termina em uma decisão documentada de aplicabilidade e evidência.

2. Operar o perfil por meio do núcleo do AI RMF

GOVERN

Estabeleça a autoridade e as condições para uso de GAI:

- atribua proprietários responsáveis e tarefas dos atores de IA;
- defina tolerância a risco, usos proibidos, uso aceitável, escalonamento e exceções;
- integre obrigações legais, de privacidade, segurança, safety, propriedade intelectual, registros, compras e incidentes;
- exija competência e independência adequadas à decisão;
- defina controles para fornecedores, código aberto, modelos, ferramentas, plugins, recuperação e uso downstream;
- proteja denunciadores e canais para relatar risco ou dano fundamentado;
- estabeleça retenção de documentos, rastreabilidade de decisões e controle de mudanças; e
- exija aprovação explícita antes de desenvolvimento, implantação, expansão ou mudança material de configuração.

MAP

Descreva o sistema real e o contexto antes de medi-lo:

- diferencie modelo base, fine-tuning, recuperacao, instrucoes de prompt/sistema, ferramentas, agentes, logica de aplicacao, interface do usuario e consumidores downstream;
- identifique finalidade pretendida, uso e uso indevido razoavelmente previsiveis, usuarios, nao usuarios e partes afetadas;
- mapeie fontes de dados e conteudo, direitos, consentimento, sensibilidade, proveniencia, transformacoes, retencao e exclusao;
- mapeie fornecedores upstream, componentes de codigo aberto, APIs, hospedagem, monitoramento e dependencias de fallback;
- avalie risco nos niveis de modelo, sistema, caso de uso e ecossistema;
- registre premissas, limitacoes, incerteza, beneficios, impactos negativos e concentracao de risco; e
- determine quais das doze familias de risco de GAI sao materiais, monitoradas, adiadas ou nao aplicaveis, com justificativa.

MEASURE

Use metodos proporcionais ao risco e a alegacao:

- valide alegacoes de capacidade e desempenho em condicoes representativas;
- teste confabulacao, confiabilidade de fontes/citacoes e comunicacao de incerteza;
- avalie vazamento de privacidade, memorizacao, inferencia e tratamento de dados sensiveis;
- teste seguranca da informacao, prompt injection, data poisoning, roubo de modelo, uso indevido de ferramentas e autonomia insegura;
- avalie vies prejudicial, homogeneizacao, conteudo perigoso, conteudo abusivo e configuracao humano-IA;
- realize avaliacao baseada em risco de capacidade CBRN e ciberofensiva quando pertinente e autorizada;
- avalie proveniencia de conteudo, rotulagem, marcas d'agua, metadados, limites de deteccao e cadeia de custodia;
- avalie riscos de propriedade intelectual e direitos sobre dados;
- meca impactos de recursos e ambientais quando materiais;
- use red teaming, feedback humano estruturado, testes de campo ou avaliacao independente conforme apropriado;
- registre escopo do teste, conjuntos de dados, ambiente, limites, limitacoes, falhas e remediacao; e
- inclua riscos que nao possam ser medidos quantitativamente na decisao de risco residual, em vez de trata-los como zero.

MANAGE

Transforme evidencia em acao responsavel:

- priorize por contexto, probabilidade ou incerteza, magnitude, escala, partes afetadas, reversibilidade e tolerancia organizacional;
- selecione tratamentos de prevencao, deteccao, resposta, recuperacao, transferencia, evitacao, aceitacao ou descontinuacao;
- defina decisoes de go, go condicional, no-go, parada, rollback, contencao e desativacao;
- atribua responsaveis e prazos de remediacao;
- monitore mudancas de modelo, sistema, uso, fornecedor, dados, conteudo e ecossistema;
- acione reavaliacao apos nova capacidade, fine-tuning, mudanca de recuperacao, acesso a ferramenta, expansao da implantacao, incidente, mudanca de fornecedor ou mudanca regulatoria;
- divulgue incidentes as partes internas e externas adequadas conforme as obrigacoes aplicaveis;
- preserve evidencia e comunique limitacoes a atores downstream e partes afetadas; e
- verifique acao corretiva e devolva as licoes a GOVERN e MAP.

Gráfico de memória do Manual 04 2

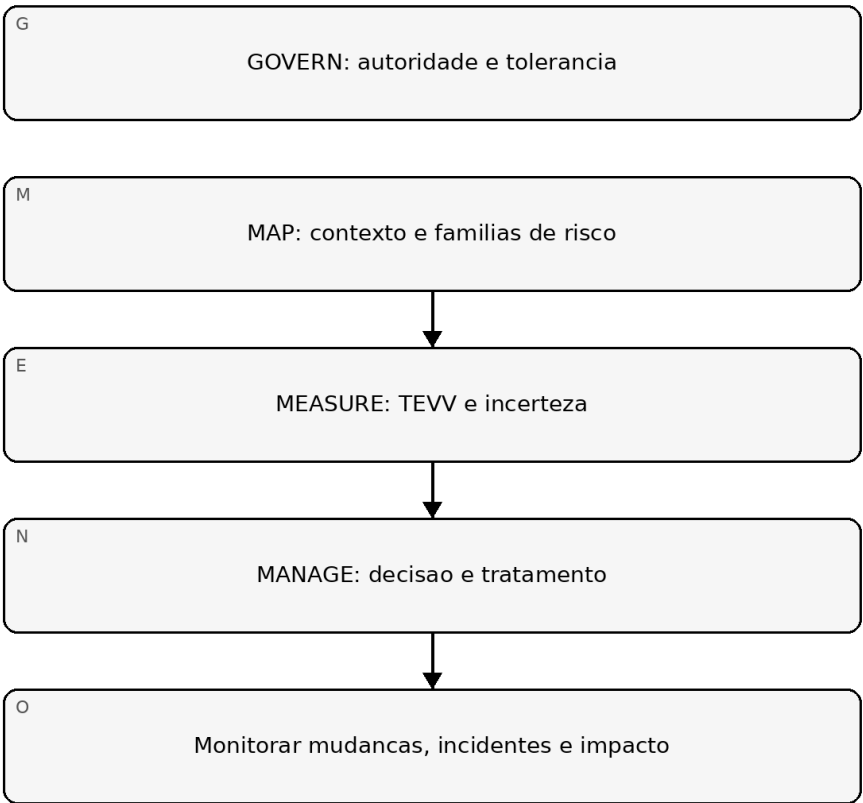


Figura 2. Gráfico de memória de implementação

Explicacao acessivel: A governanca define autoridade e tolerancia; o mapeamento estabelece contexto e riscos de GAI relevantes; a medicao produz evidencia de testes e incerteza; a gestao toma e aplica decisoes. O monitoramento devolve informacoes sobre mudancas, incidentes e impactos para a governanca.

3. Avaliar as doze familias de risco

Para cada modelo, sistema, aplicacao ou caso de uso, registre uma disposicao para cada familia:

Familia de risco	Pergunta minima de implementacao	Exemplo de evidencia
Informacao ou capacidades CBRN	O sistema poderia reduzir materialmente as barreiras para atividade biologica, quimica, radiologica ou nuclear prejudicial?	Testes de capacidade autorizados, limites de acesso, registros de escalonamento
Confabulacao	Uma saida falsa ou sem suporte poderia causar decisoes materiais, dano ou perda?	Testes de grounding, verificacoes de citacao, limites de revisao humana
Conteudo perigoso, violento ou de odio	Entradas ou saidas podem facilitar violencia, odio, extremismo ou atividade perigosa?	Avaliacoes de safety, resultados de moderacao, monitoramento de uso indevido
Privacidade de dados	Treinamento, recuperacao, prompts, logs ou saidas podem expor ou inferir dados sensiveis?	Mapa de fluxo de dados, testes de privacidade, evidencia de retencao e exclusao
Impactos ambientais	Os impactos de recursos de treinamento ou inferencia sao materiais para a	Estimativas de energia/recursos, decisoes de eficiencia, monitoramento

Familia de risco	Pergunta minima de implementacao	Exemplo de evidencia
	decisao?	
Vies prejudicial e homogeneizacao	As saidas criam danos desiguais, falha correlacionada ou reducao de diversidade?	Testes por subpopulacao, feedback de partes afetadas, resultados de mitigacao
Configuracao humano-IA	Usuarios podem depender excessivamente, interpretar incorretamente, antropomorfizar ou perder supervisao efetiva?	Testes de UX, instrucoes, evidencia de carga de trabalho e override
Integridade da informacao	Conteudo gerado pode comprometer proveniencia, autenticidade, confianca publica ou decisoes?	Projeto de proveniencia, testes de rotulagem, divulgacao e monitoramento
Seguranca da informacao	O sistema pode ser atacado ou usado indevidamente por prompts, dados, modelos, ferramentas, APIs ou agentes?	Modelo de ameaças, resultados de red team, controles de acesso e logging
Propriedade intelectual	Direitos de treinamento, entrada, saida ou distribuicao sao incertos ou violados?	Registro de direitos, analise contratual, controles de revisao de saida
Conteudo obsceno, degradante e/ou abusivo	O sistema pode criar ou ampliar conteudo sexual, degradante, exploratorio ou abusivo?	Testes de safety, moderacao, processo de denuncia e apoio a vitimas
Cadeia de valor e integracao de componentes	Dependencias upstream ou downstream podem criar risco opaco, concentrado ou em cascata?	Inventario de fornecedores, contratos, avisos de mudanca, testes de fallback

Nenhuma familia pode ser omitida. Nao aplicavel exige justificativa registrada e gatilho de reconsideracao. Uma familia pode ser material em um nivel e nao em outro; por exemplo, um risco do modelo base pode ser controlado na camada de aplicacao enquanto a dependencia do ecossistema permanece.

4. Adaptar acoes sugeridas sem perder responsabilidade

Use um registro de aplicabilidade com estes campos:

- ID da acao NIST e subcategoria do AI RMF;
- familias de risco de GAI relevantes;
- tarefas aplicaveis dos atores de IA;
- escopo de modelo, sistema, caso de uso e ecossistema;
- disposicao: adotar, adaptar, controle equivalente, adiar ou nao aplicavel;
- justificativa e fonte do requisito;
- proprietario responsavel e autoridade de aprovacao;
- evidencia de implementacao;
- teste de efetividade e resultado;
- risco residual e data de expiracao/revisao; e
- mudancas ou incidentes que reabrem a decisao.

Um controle equivalente deve atingir o mesmo objetivo de risco no contexto real. O adiamento deve declarar a lacuna de evidencia, controle temporario, responsavel, prazo e exposicao aceita. Decisoes de nao aplicabilidade nao devem ser usadas para evitar risco material que seja dificil de medir.

5. Definir gates de liberacao e operacao

Antes da implantacao ou expansao material, exija evidencia de que:

- usos pretendidos e previsiveis estejam documentados;
- familias de risco relevantes tenham sido avaliadas;
- testes requeridos tenham atingido limites aprovados;
- achados criticos e altos estejam resolvidos ou explicitamente rejeitados por aceitacao de risco autorizada;
- supervisao humana seja competente, disponivel e efetiva;
- riscos de fornecedores e componentes estejam dentro da tolerancia;
- controles de proveniencia de conteudo e divulgacao sejam adequados a finalidade;
- monitoramento, divulgacao de incidentes, parada, rollback e fallback estejam operacionais;

- usuarios e atores downstream recebam limitacoes e instrucoes necessarias; e
- risco residual seja aprovado pela autoridade correta.

Gatilhos de parada ou rollback devem incluir violacao de limite, nova capacidade perigosa, falha de controle, evento material de privacidade/seguranca, saida prejudicial repetida, supervisao nao confiavel, perda de fornecedor, drift inexplicado, incidente grave ou evidencia de que o uso real difere materialmente do contexto aprovado.

6. Preservar o ciclo de evidencia e decisao

Gráfico de memória do Manual 04 3

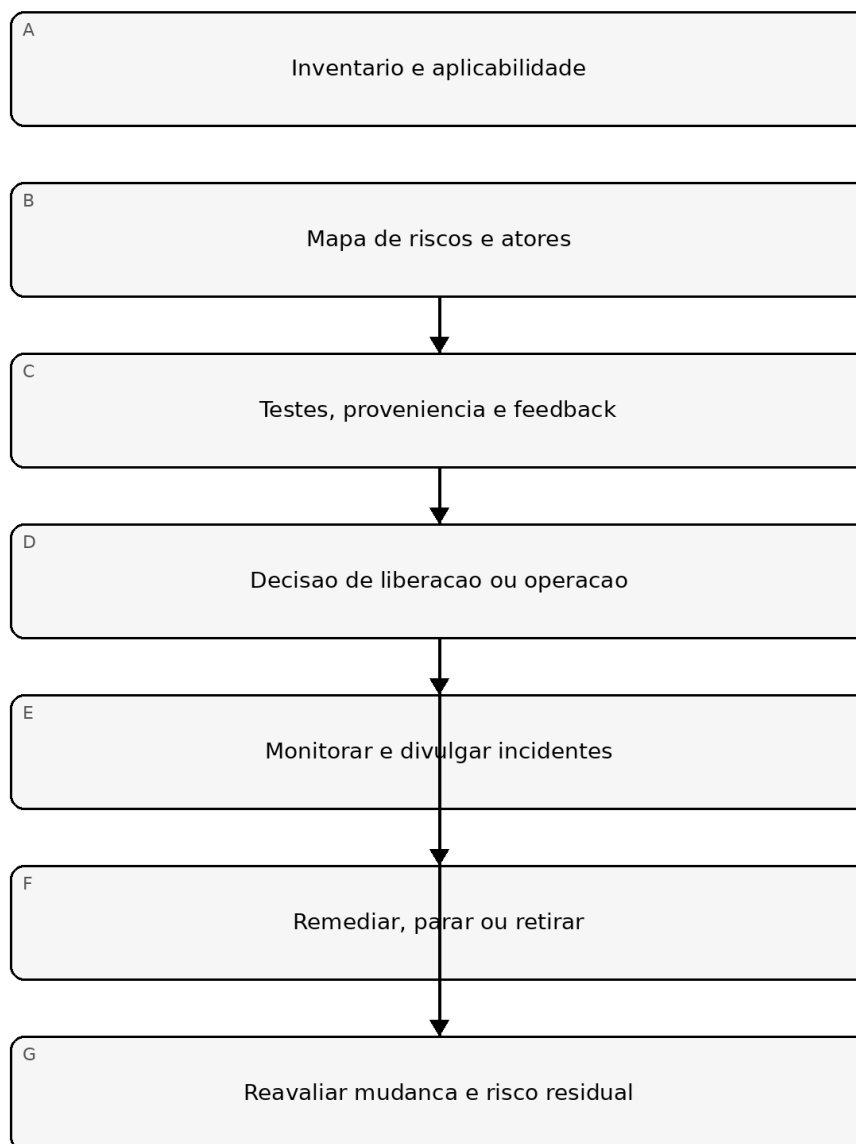


Figura 3. Gráfico de memória de implementação

Explicacao acessivel: O ciclo de evidencias comea com inventario e aplicabilidade, depois mapeia riscos e atores, coleta testes e feedback e chega a uma decisao responsavel. Uso aprovado ou condicional e monitorado; uso rejeitado e remediado, interrompido ou retirado. A reavaliacao de mudancas e risco residual reinicia o ciclo.

7. Critérios de conclusão para analistas e gestores

Um analista deve conseguir demonstrar:

- a fonte NIST exata e a versão controlada utilizada;
- os limites relevantes de modelo/sistema/caso de uso/ecossistema;
- a disposição de cada família de risco;
- evidência de aplicabilidade e adaptação das ações;
- rastreabilidade de fonte para controle, teste e decisão;
- premissas, limitações e lacunas de evidência abertas; e
- registros de monitoramento, incidentes e reavaliação.

Um gestor deve conseguir responder:

- quem é dono do risco e quem pode aprovar, parar ou reverter o sistema;
- quais danos ou falhas excedem a tolerância;
- quais evidências sustentam a decisão e o que permanece incerto;
- se supervisão humana e controles de fornecedores funcionam na prática;
- como partes afetadas e atores downstream são protegidos e informados;
- quais mudanças invalidam a aprovação; e
- se o risco residual continua aceitável.

Declaração de assecuração

Esta incorporação de implementação apoia o uso controlado e baseado em evidências do NIST AI 600-1. Ela não certifica um sistema, não substitui lei ou contrato aplicável, não prova que todas as ações sugeridas se aplicam, não estabelece conformidade legal e não fornece uma opinião de auditoria. Revisores humanos e decisores autorizados continuam responsáveis por aplicabilidade, semântica, aceitação de risco e liberação.

Manual controlado de 32 capítulos

Capítulo 01 — Propósito, escopo e aplicabilidade

Este manual operacionaliza a gestão de riscos de IA generativa para organizações que projetam, adquirem, integram, implantam, operam ou desativam capacidades de IA generativa. O limite de implementação é deliberadamente baseado em risco: nem todo controle, teste, evidência ou prática operacional se aplica a todo caso de uso.

Cada implementação começa com uma decisão documentada de aplicabilidade cobrindo caso de uso, partes afetadas, contexto de implantação, dados tratados, autonomia, dependências externas e consequências de erro ou uso indevido. O registro de aplicabilidade torna-se evidência controlada e deve ser revisto quando sistema, modelo, dados, ferramentas, fornecedor ou contexto operacional mudarem materialmente.

Evidência mínima:

- descrição do caso de uso e responsável de negócio;
- referência ao inventário do sistema/modelo/componente;
- identificação das partes afetadas e partes interessadas;
- nível de risco ou classificação equivalente;
- justificativa de aplicabilidade;
- revisor e data de aprovação.

Capítulo 02 — Relação com AI RMF 1.0

NIST AI 600-1 é tratado como perfil de IA generativa e recurso complementar ao AI RMF, não como checklist universal independente. O modelo operacional mantém GOVERN, MAP, MEASURE e MANAGE como ciclo de gestão, acrescentando famílias de risco específicas de IA generativa, expectativas de teste, considerações de proveniência e sinais de incidente.

As organizações deveriam mapear cada decisão de implementação à função relevante do AI RMF e preservar rastreabilidade da declaração de risco até evidência, decisão, ação e risco residual.

Comportamento de controle requerido:

- GOVERN define política, responsabilidade, autoridade e escalonamento;
- MAP define contexto, uso, atores, dependências e danos plausíveis;
- MEASURE avalia desempenho, segurança, cibersegurança, privacidade, integridade e incerteza;
- MANAGE seleciona tratamentos, aceita risco residual, monitora a operação e aciona parar/reverter quando limites são excedidos.

Capítulo 03 — Caminhos de implementação

Três caminhos proporcionais são suportados.

Essencial

Para usos de menor complexidade ou impacto. Requer inventário, responsáveis, triagem básica de risco, testes mínimos, supervisão humana, tratamento de incidentes e aprovação documentada.

Estruturado

Para usos materiais de negócio, clientes, força de trabalho, segurança, privacidade, finanças ou operações. Requer registros formais de risco, matrizes de evidência, planos de teste, revisão de fornecedores, controles de mudança, limites de monitoramento, playbooks de incidente e reavaliação periódica.

Reforçado

Para usos de alto impacto, alta autonomia, sensíveis à segurança, regulados, expostos externamente ou de outra forma consequenciais. Requer desafio independente, testes adversariais mais profundos, critérios formais de liberação, proveniência reforçada, autoridade explícita para parar/reverter, monitoramento reforçado e aceitação documentada do risco residual pela gestão responsável.

A seleção do caminho deve ser justificada e só pode ser reduzida mediante aprovação documentada.

Capítulo 04 — Governança e responsabilização

Todo sistema de IA generativa deve ter responsáveis de negócio, técnicos, de segurança, privacidade/dados e risco adequados ao seu escopo. A responsabilidade não pode ser delegada apenas ao fornecedor do modelo ou implementador.

A governança deveria definir quem pode aprovar novo caso de uso, mudanças em modelo/prompt/recuperação/ferramentas/dados, quem responde por testes e evidência, quem pode suspender ou reverter implantação, quem aceita risco residual, quem recebe notificações de incidente e quem conduz revisão periódica.

Conflitos de interesse devem ser identificados quando a mesma pessoa projeta, testa e aprova sistema de alto impacto. Implementações reforçadas deveriam adicionar revisão ou desafio independente.

Capítulo 05 — Inventário e decomposição do sistema

Trate a capacidade de IA generativa como sistema, não apenas modelo. O inventário deveria identificar modelo, hospedagem, camada de recuperação, armazenamento vetorial, prompts/instruções do sistema, ferramentas, APIs, fontes de dados, artefatos de fine-tuning, guardrails, monitoramento, serviços externos e pontos de decisão humana.

O inventário deveria registrar versão, responsável, fornecedor, localização, classificação de dados, limite de autenticação, autoridade de mudança e status de desativação. Dependências capazes de alterar materialmente saída ou comportamento devem ser rastreáveis separadamente.

Uma mudança é material quando pode alterar risco, capacidade, exposição, qualidade de saída, segurança, cibersegurança, privacidade, postura de conformidade ou impacto sobre partes afetadas.

Capítulo 06 — Modelo de famílias de risco de IA generativa

A linha de base controlada do Manual 04 preserva doze famílias de risco de IA generativa:

1. Informações ou capacidades CBRN
2. Confabulação
3. Conteúdo perigoso, violento ou de ódio
4. Privacidade de dados
5. Impactos ambientais
6. Viés prejudicial e homogeneização
7. Configuração humano-IA
8. Integridade da informação
9. Segurança da informação
10. Propriedade intelectual
11. Conteúdo obsceno, degradante e/ou abusivo
12. Integração da cadeia de valor e componentes

Essas famílias são categorias de triagem, não achados automáticos. Cada caso de uso deve determinar famílias aplicáveis, cenários plausíveis, controles existentes, evidência, risco residual e indicadores de monitoramento.

Capítulo 07 — Declarações de risco e caminhos de impacto

Os registros de risco deveriam ser baseados em cenários. Uma estrutura útil é:

Condição ou ameaça → comportamento do sistema → ativo/pessoa/processo afetado → consequência → controle/evidência → risco residual.

Por exemplo, um assistente com recuperação pode ingerir conteúdo não confiável, seguir instruções maliciosas incorporadas, invocar ferramenta externa e expor informação restrita. A declaração deveria descrever o caminho completo e não apenas rotular o problema como “prompt injection”.

A análise de impacto deveria considerar efeitos diretos, indiretos, cumulativos e de uso indevido previsível. Quando os impactos forem incertos, a incerteza deve ser registrada em vez de convertida silenciosamente em conclusão de baixo risco.

Capítulo 08 — Autoridade de liberação e gates fail-closed

Nenhum caso de uso de IA generativa deveria ir para produção apenas porque testes automatizados passaram. A liberação requer evidência documentada suficiente para o caminho escolhido, exceções não resolvidas dentro da tolerância aprovada, aprovação dos responsáveis e qualquer revisão humana exigida.

Um gate de liberação deve falhar fechado quando faltar evidência ou estiver desatualizada; testes obrigatórios estiverem incompletos ou falharem; achados críticos permanecerem abertos sem tratamento aprovado; revisão humana obrigatória estiver ausente, rejeitada ou invalidada por mudança material; aplicabilidade legal, de segurança, privacidade, proteção ou operação estiver sem solução; ou capacidade exigida de parar/reverter não estiver validada.

Mudança material após aprovação reabre os gates de revisão e liberação afetados.

Capítulo 09 — Confabulação e confiabilidade das saídas

O risco de confabulação é gerenciado por avaliação específica do caso de uso, não por um único percentual de precisão. As equipes deveriam identificar quais afirmações precisam ser factuais, a taxa de erro aceitável, as consequências de falsa confiança e os controles usados quando o modelo não possui suporte confiável.

Controles úteis incluem recuperação fundamentada, exibição de fontes, geração restrita, comportamento de abstenção, validação humana, verificações determinísticas posteriores e restrições a ações autônomas de alta consequência. A evidência deveria incluir conjuntos de avaliação, limites de aceitação, falhas observadas, exemplos representativos, decisões de remediação e aprovação do risco residual.

Capítulo 10 — Conteúdo nocivo, abusivo e perigoso

As organizações deveriam definir categorias de conteúdo proibido, restrito, dependente do contexto ou aceitável para o caso de uso. A política deve distinguir o tratamento de entradas do usuário do tratamento de saídas do modelo e tratar tentativas adversariais de contornar salvaguardas.

Os testes deveriam incluir uso esperado, uso indevido, condições de limite, manipulação de prompts, variação multilíngue quando relevante e comportamento de escalonamento. Um mecanismo de recusa que possa ser contornado trivialmente não deve ser tratado como controle efetivo.

Capítulo 11 — Privacidade de dados e informações sensíveis

A revisão de privacidade deveria rastrear dados por prompts, armazenamentos de recuperação, logs, treinamento ou fine-tuning, APIs externas, plataformas de observabilidade, canais de suporte e histórico de conversas retido.

O conjunto mínimo de controles deveria abordar minimização, limitação de finalidade, acesso, retenção, exclusão, redação, tratamento de segredos, registro, processamento por terceiros e divulgação ao usuário quando aplicável. Os testes deveriam procurar memorização, vazamento de dados, sobre-exposição por recuperação, contaminação entre usuários e divulgação não autorizada por ferramentas ou conectores.

Capítulo 12 — Viés prejudicial, homogeneização e impacto humano

A avaliação de vies deveria estar ligada às decisões, recomendações, classificações, conteúdos ou experiências produzidas pelo sistema. As equipes deveriam identificar populações ou partes interessadas que possam sofrer taxas de falha ou danos diferentes.

Controles podem incluir análise de dados, testes de resultados, avaliação por subgrupos, escalonamento humano, fluxos alternativos, monitoramento e restrições ao uso de conteúdo gerado em decisões consequenciais. Quando a medição for limitada por dados ou tamanho da amostra, essa incerteza deve ser documentada e não apresentada como evidência de equidade.

Capítulo 13 — Configuração humano-IA e supervisão

A supervisão humana deve ser projetada, não presumida. A organização deveria determinar o que se espera que a pessoa perceba, que evidência está disponível, se há tempo e autoridade suficientes para intervir e como o viés de automação será reduzido.

Para usos consequenciais, defina decisões que o sistema pode tomar ou recomendar, decisões reservadas a humanos, gatilhos de escalonamento, autoridade de override, registro da revisão humana, requisitos de competência e procedimentos alternativos quando o sistema estiver indisponível ou não confiável.

Capítulo 14 — Integridade da informação e proveniência

Controles de integridade deveriam ajudar usuários a distinguir informação gerada, recuperada, transformada e autoritativa. A proveniência deveria ser preservada quando afetar materialmente confiança, revisão, atribuição ou uso posterior.

A evidência pode incluir referências de fonte, metadados, artefatos assinados, histórico de transformações, identificadores de prompt/versão, registros de modelo e rastreabilidade da saída até material de suporte. Alegações de proveniência devem ser limitadas: metadados ou rótulos melhoram rastreabilidade, mas não provam por si só verdade ou autenticidade.

Capítulo 15 — Segurança da informação e testes adversariais

Os testes de segurança de IA generativa deveriam cobrir toda a superfície de ataque: prompts, fontes de recuperação, bancos vetoriais, endpoints de modelo, plugins/ferramentas, identidades, segredos, APIs, interfaces, logs, camadas de orquestração e integrações com fornecedores.

Os testes deveriam incluir prompt injection direto e indireto, uso não autorizado de ferramentas, elevação de privilégios, extração de dados sensíveis, conteúdo malicioso de recuperação, divulgação do prompt do sistema, abuso de ações externas e cenários de negação ou degradação quando relevantes. Os achados devem ser vinculados a controles, responsáveis, remediação, evidência de reteste e decisões de risco residual.

Capítulo 16 — Propriedade intelectual, cadeia de valor e integração de componentes

A organização deveria identificar componentes licenciados, proprietários, de terceiros, open source e hospedados externamente que influenciam o sistema. Quando relevante, termos do fornecedor, restrições de uso, direitos sobre saídas, termos de processamento de dados e dependências devem ser documentados.

A revisão da cadeia de valor deveria incluir fornecedores de modelos, hospedagem, conjuntos de dados, fontes de recuperação, plugins, APIs, serviços de segurança, monitoramento e subprocessadores. Um questionário de fornecedor isolado não constitui evidência suficiente para dependências de alto risco. Mudanças materiais de fornecedor ou componente devem acionar reavaliação quando puderem alterar capacidade, tratamento de dados, exposição contratual, segurança, disponibilidade ou comportamento das saídas.

Capítulo 17 — Estratégia de avaliação

A avaliação começa com uma pergunta documentada: o que o sistema deve conseguir fazer, o que deve evitar, sob quais condições e com qual nível de confiança. A estratégia deveria definir objetivos, cenários, conjuntos de dados, avaliadores, métodos, limites, amostragem, limitações e regras de decisão.

A avaliação deveria incluir uso normal representativo e uso indevido plausível. Sistemas de alto impacto deveriam usar desafio independente ou separação entre construtores e responsáveis pela decisão final de liberação.

Capítulo 18 — Governança de dados de teste e cenários

Os dados de teste deveriam ser rastreáveis ao propósito. As equipes deveriam registrar origem, cobertura, sensibilidade, transformação, representatividade, limitações conhecidas e se os dados podem ser retidos ou compartilhados.

Dados sintéticos podem melhorar cobertura, mas não devem ser presumidos representativos de populações reais ou comportamento adversarial. Quando usados, o registro de avaliação deveria explicar por que são apropriados e quais pontos cegos permanecem.

Capítulo 19 — Limites de aceitação e critérios de decisão

Os limites deveriam ser definidos antes dos testes finais quando praticável e refletir consequências, não conveniência. Um assistente de redação de baixo impacto pode tolerar taxas de falha diferentes de um sistema que influencie decisões de segurança, finanças, saúde, emprego ou proteção.

A decisão de liberação deveria registrar se cada limite passou, falhou, foi aceito condicionalmente ou dispensado. Dispensas exigem justificativa, responsável, controle compensatório, data de expiração ou revisão e aprovação do risco residual.

Capítulo 20 — Red teaming e avaliação adversarial

A avaliação adversarial deveria testar se controles permanecem efetivos quando usuários ou conteúdo externo tentam contorná-los intencionalmente. Casos de teste deveriam abordar manipulação direta de prompts, instruções indiretas, envenenamento de recuperação, abuso de ferramentas, falhas de identidade/permissão, extração de dados, divulgação do prompt do sistema e encadeamento inseguro de ações quando aplicável.

Resultados de red team devem ser tratados como evidência, não como espetáculo. Testes repetidos sem responsável de remediação ou reteste não devem ser representados como garantia.

Capítulo 21 — Controles de proveniência de conteúdo

A proveniência deveria apoiar perguntas práticas: qual modelo e configuração produziu a saída, quais dados ou fontes influenciaram materialmente, quais transformações ocorreram e quem ou o que aprovou o uso posterior.

A organização deveria selecionar mecanismos proporcionais ao risco, como links de fonte, hashes de artefatos, identificadores de modelo/versão, versões de prompts ou políticas, logs de transformação, registros de aprovação humana ou metadados assinados. A proveniência melhora rastreabilidade, mas não prova sozinha precisão factual ou origem lícita.

Capítulo 22 — Pacote de testes pré-implantação

Um pacote de evidência pré-implantação deveria reunir o necessário para uma decisão responsável. No mínimo, deveria incluir inventário do sistema/caso de uso, registro de riscos e impactos, plano e resultados de avaliação, resultados de testes de segurança/adversariais, revisão de privacidade/dados quando aplicável, evidência de fornecedores/componentes, achados e exceções abertos, limites de monitoramento, plano de parar/reverter e registro de aprovação.

O pacote deve ser versionado e vinculado ao candidato exato de liberação.

Capítulo 23 — Preparação para divulgação e escalonamento de incidentes

Antes da implantação, a organização deveria definir quais eventos qualificam como incidentes de IA generativa, quem deve ser informado, que evidência deve ser preservada e quando notificação ou divulgação externa pode ser exigida.

Categorias podem incluir saída nociva, exposição de dados, ação não autorizada, contorno de controle, falha de fornecedor, desinformação material, autonomia inesperada, violação regulatória ou contratual ou repetida violação de limites. Critérios de escalonamento deveriam ser explícitos o suficiente para evitar improvisação durante um evento.

Capítulo 24 — Suficiência de evidência e qualidade da revisão

A evidência deveria demonstrar que um controle operou para o sistema e período relevantes. Políticas, capturas de tela, alegações de fornecedor ou questionários podem apoiar a evidência, mas não devem ser automaticamente tratados como prova de efetividade.

Revisores deveriam considerar relevância, confiabilidade, completude, tempestividade e independência. Quando a evidência for fraca ou indisponível, o registro deve declarar essa limitação e o efeito resultante sobre risco residual ou confiança na liberação.

Capítulo 25 — Controles de implantação e liberação

A implantação deveria usar um registro controlado vinculado ao artefato testado, configuração, versão do modelo, estado de dados/recuperação, ferramentas, guardrails e condições operacionais aprovadas. Desvio material entre o candidato testado e o sistema implantado invalida a evidência de liberação até ser avaliado.

Os registros deveriam identificar aprovadores responsáveis, exceções abertas, limites de monitoramento, autoridade de reversão e datas de revisão.

Capítulo 26 — Monitoramento e limites operacionais

O monitoramento deveria estar ligado a riscos conhecidos e limites de decisão, não a telemetria genérica. Medidas relevantes podem incluir taxas de saídas nocivas, respostas sem suporte, eventos de segurança, sinais de vazamento de dados, reclamações de usuários, falhas de ferramentas, indicadores de drift do modelo, latência/disponibilidade, mudanças de fornecedores e volume de exceções.

Violações de limite deveriam mapear para ações predefinidas: investigar, restringir, aumentar revisão humana, desabilitar função, reverter ou parar o sistema.

Capítulo 27 — Gestão de mudanças e reavaliação

Mudanças em modelos, prompts, instruções do sistema, fontes de recuperação, ferramentas, permissões, tratamento de dados, fornecedores, guardrails, interfaces ou uso de negócio podem alterar risco. Registros de mudança deveriam classificar materialidade e identificar quais evidências anteriores permanecem válidas.

Mudanças materiais reabrem gates afetados de risco, teste, segurança, privacidade, acessibilidade, revisão humana e liberação. Mudanças emergenciais exigem revisão retrospectiva e conclusão de evidências dentro de período definido.

Capítulo 28 — Resposta a incidentes e contenção

A resposta a incidentes de IA generativa deveria integrar-se à gestão corporativa de incidentes preservando evidência específica de IA. As equipes deveriam capturar prompts, saídas, identificadores de modelo/configuração, contexto de recuperação, chamadas de ferramentas, identidades, horários, logs, registros afetados, avisos de fornecedores e estado de controles quando lícito e viável.

Opções de contenção podem incluir desabilitar ferramentas, reduzir permissões, isolar fontes de recuperação, reverter configuração, limitar usuários, aumentar revisão humana ou suspender o serviço.

Capítulo 29 — Ação corretiva e validação de remediação

A ação corretiva deveria tratar causas raiz e não apenas suprimir a saída observada. Registros deveriam identificar achado, causa, responsável, ação planejada, data-alvo, método de validação, evidência, risco residual e decisão de encerramento.

Uma correção não deve ser considerada encerrada apenas porque um caso de teste agora passa. O reteste deveria avaliar variantes prováveis e risco de regressão.

Capítulo 30 — Revisão periódica e relatórios gerenciais

A revisão periódica deveria avaliar se o caso de uso permanece apropriado, controles continuam efetivos, premissas de risco permanecem válidas, evidência está atualizada, fornecedores ou componentes mudaram e resultados operacionais permanecem dentro da tolerância.

Relatórios gerenciais deveriam distinguir fatos, tendências, premissas, riscos não resolvidos, exceções aceitas e decisões exigidas. Questões de alto risco deveriam ser visíveis ao responsável pelo risco, não ocultas em relatórios técnicos.

Capítulo 31 — Desativação, disposição de dados e saída

O planejamento de desativação deveria tratar endpoints de modelo, credenciais, prompts, índices de recuperação, armazenamentos vetoriais, logs, dados de usuários, caches, integrações, acesso de fornecedores, evidência retida e obrigações contratuais.

A organização deveria verificar devolução ou exclusão de dados quando exigida, revogar acessos e segredos, desabilitar integrações, preservar registros exigidos, documentar obrigações não resolvidas e registrar a decisão de desativação.

Capítulo 32 — Garantia, limitações e limite final de liberação

A garantia é cumulativa e específica ao escopo. QA do repositório, testes automatizados, red teaming, documentação ou checklist concluído não garantem que um sistema de IA generativa seja seguro, protegido, conforme, preciso, justo ou adequado a todos os contextos.

Antes da publicação deste manual, o pacote controlado deve concluir verificação de fontes, revisão técnica/editorial, revisão semântica es-419 e pt-BR, verificação de gráficos/acessibilidade, geração DOCX/PDF, QA por página, proveniência e checksums, revisão de repositório/segurança e Aprovação Humana Final de Liberação explícita.

Qualquer mudança material de conteúdo após aprovação humana reabre o gate de revisão afetado.